Cyberster Red Team Internship

LET'S DEFEND WITH PRIDE

Weekly Report

Name: Angole Sharif Abubakar
Program: Cyberster-2026
Field: Cybersecurity / Red Teaming

Role Number: CSI-B1-023
Week Number: Two
Report Period: One Week
Submission Date: 14th March 2026

---

1. Executive Summary

Objective: Assess the Metasploitable2 VM for exposed services and misconfigurations through active enumeration and vulnerability discovery.

Key Points:

- **Critical Findings:**
  - FTP service running vsftpd 2.3.4 with a known backdoor (CVE-2011-2523).
  - Samba 3.0.20 vulnerable to usermap exploit (CVE-2007-2447).
- **High Findings:**
  - Anonymous SMB access enabled.
  - Default accounts (msfadmin, postgres, mysql) present.
- **Medium Findings:**
  - Outdated Apache 2.2.8 web server with multiple CVEs.
- **Low Findings:**
  - Banner disclosures across FTP, SMTP, and Telnet.

Business Impact: Exploitation of these services could lead to **remote code execution, unauthorized access to sensitive data, and lateral movement** within the environment.

Overall Risk Rating: **High Risk**

Recommendations:

- Patch or remove vulnerable services (FTP, Samba).
- Disable anonymous SMB access.
- Enforce strong password policies.
- Upgrade outdated web server software.

---

2. Scope

- **In-Scope Assets:** Metasploitable2 VM (IP: 192.168.1.4).
- **Out-of-Scope Assets:** External networks, production systems.
- **Testing Window:** 8th – 15th March 2026.
- **Constraints:** No DoS testing, controlled lab environment.

3. Methodology

- **Reconnaissance:** Host discovery and port scanning with Nmap.
- **Scanning:** TCP Connect (-sT), SYN Stealth (-sS), UDP (-sU), NSE scripts.
- **Enumeration:** Service fingerprinting, banner grabbing, SMB enumeration.
- **Evasion:** Fragmentation, MTU manipulation, decoys, source port spoofing.
- **Frameworks Referenced:** PTES, OWASP Testing Guide, NIST SP 800-115.

4. Findings

Task 1 – Advanced Network Scanning with Nmap

Description:
Performed deep port scans using Nmap to identify open services. Compared **TCP Connect (-sT)** and **SYN Stealth (-sS)** scans for speed and visibility. Conducted **UDP scans (-sU)** on the top 100 ports. Tested timing templates (-T0 to -T5) to evaluate stealth vs speed.

Commands Used:

- nmap -sT 192.168.1.4
- sudo nmap -sS 192.168.1.4
- sudo nmap -sU --top-ports 100 192.168.1.4
- nmap -sS -T2 192.168.1.4
- nmap -sS -T4 192.168.1.4

```
┌──(kali㉿kali)-[~/Desktop/cy63rst3r-2026/Week2-Tasks/Raw-Data]
└─$ nmap -sS -p 1-1000 192.168.1.4 -oN sS.txt
```

```
┌──(kali㉿kali)-[~/Desktop/cy63rst3r-2026/Week2-Tasks/Raw-Data]
└─$ nmap -sT -p 1-1000 192.168.1.4 -oN sT.txt
```

```
┌──(kali㉿kali)-[~/Desktop/cy63rst3r-2026/Week2-Tasks/Raw-Data]
└─$ nmap -sU --top-ports 100 192.168.1.4 -oN sU.txt
```

```
┌──(kali㉿kali)-[~/Desktop/cy63rst3r-2026/Week2-Tasks/Raw-Data]
└─$ nmap -sS -T4 -p 1-1000 192.168.1.4 -oN T4-sS.txt
```

```
┌──(kali㉿kali)-[~/Desktop/cy63rst3r-2026/Week2-Tasks/Raw-Data]
└─$ nmap -sT -T4 -p 1-1000 192.168.1.4 -oN T4-sT.txt
```

Explanation:

- TCP Connect scans were reliable but noisy.
- SYN Stealth scans were faster and stealthier, preferred in Red Teaming.
- UDP scans revealed SNMP/DNS but were slow.
- Timing templates showed **T0 was stealthy but slow**, while **T4 balanced speed and reliability**.

Task 2 – Service Fingerprinting & Banner Grabbing

Description:
Identified service versions and banners using Nmap's **version detection (-sV)** and **aggressive scan (-A)**. Verified banners manually with **Netcat (nc)** and **Telnet**. Enumerated SMB shares and users using **enum4linux** and **smbclient**.

Commands Used:

- nmap -sV 192.168.1.4
- nmap -A 192.168.1.4
- nc 192.168.1.4 21
- telnet 192.168.1.4 25
- enum4linux -a 192.168.1.4
- smbclient //192.168.1.4/tmp -N

```
┌──(kali㉿kali)-[~/Desktop/cy63rst3r-2026/Week2-Tasks]
└─$ nmap -A -p 1-1000 192.168.1.4
```

```
┌──(kali㉿kali)-[~/Desktop/cy63rst3r-2026/Week2-Tasks]
└─$ nc 192.168.1.4 80
```

```
┌──(kali㉿kali)-[~/Desktop/cy63rst3r-2026/Week2-Tasks]
└─$ smbclient -L 192.168.1.4 -N
```

```
┌──(kali㉿kali)-[~/Desktop/cy63rst3r-2026/Week2-Tasks/Raw-Data]
└─$ nmap -sV -p 1-1000 192.168.1.4 -oN sV.txt
```

```
┌──(kali㉿kali)-[~/Desktop/cy63rst3r-2026/Week2-Tasks]
└─$ telnet 192.168.1.4 80
```

Explanation:

- FTP revealed **vsftpd 2.3.4**, vulnerable to a backdoor exploit.
- Telnet showed default login prompts, indicating weak credential policies.
- Apache 2.2.8 was outdated, exposing multiple CVEs.

- SMB enumeration revealed anonymous access and multiple system accounts (root, msfadmin, postgres, mysql).

Task 3 – Leveraging Nmap Scripting Engine (NSE)

Description:
Automated vulnerability discovery using Nmap's scripting engine. Ran **Discovery** and **Safe** scripts for service info, and **Vuln** scripts to identify exploitable vulnerabilities mapped to CVEs.

Commands Used:

- nmap -sV --script discovery, safe 192.168.1.4
- nmap --script vuln 192.168.1.4

```
┌──(kali㉿kali)-[~/Desktop/cy63rst3r-2026/Week2-Tasks/Raw-Data]
└─$ cat nse-safe.txt
Starting Nmap 7.98 ( https://nmap.org ) at 2026-03-14 10:12 -0400
No profinet devices in the subnet
Pre-scan script results:
| targets-ipv6-multicast-invalid-dst:
|   IP: fe80::a00:27ff:fe4f:475a  MAC: 08:00:27:4f:47:5a  IFACE: eth0
|_  Use --script-args=newtargets to add the results as targets
| eap-info:
| Available authentication methods with identity="anonymous" on interface eth0
|   unknown  EAP-TTLS
|   unknown  EAP-TLS
|   unknown  EAP-MSCHAP-V2
|_  unknown  PEAP
|_hostmap-robtex: *TEMPORARILY DISABLED* due to changes in Robtex's API. See https://www.robtex.com/ap
| broadcast-dhcp-discover:
|   Response 1 of 1:
|     Interface: eth0
|     IP Offered: 192.168.1.6
|     Server Identifier: 192.168.1.2
```

Explanation:

- Discovery scripts identified web directories and SSL certificate details.
- Safe scripts revealed anonymous SMB shares and user accounts.
- Vuln scripts confirmed the **vsftpd backdoor (CVE-2011-2523)** and **Samba exploit (CVE-2007-2447)**.

Task 4 – Stealth & Firewall Evasion

Description:
Tested stealth and evasion techniques to bypass IDS/firewall rules. Techniques included **packet fragmentation (-f)**, **MTU manipulation (--mtu)**, **decoys (-D)**, and **source port spoofing (--source-port)**.

Commands Used:

- nmap -sS -f 192.168.1.4
- nmap -sS --mtu 24 192.168.1.4
- nmap -sS -D RND:10 192.168.1.4
- nmap -sS --source-port 53 192.168.1.4

```
┌──(kali㉿kali)-[~/Desktop/cy63rst3r-2026/Week2-Tasks/Raw-Data]
└─$ nmap -sS -D RND:15 192.168.1.4
```

```
┌──(kali㉿kali)-[~/Desktop/cy63rst3r-2026/Week2-Tasks/Raw-Data]
└─$ sudo nmap -sS -p 1-1000 -f 192.168.1.4 -oN f-sS.txt
```

```
┌──(kali㉿kali)-[~/Desktop/cy63rst3r-2026/Week2-Tasks/Raw-Data]
└─$ nmap -sS --mtu 24 192.168.1.4
```

```
┌──(kali㉿kali)-[~/Desktop/cy63rst3r-2026/Week2-Tasks/Raw-Data]
└─$ nmap -sS --source-port 53 192.168.1.4
```

Explanation:

- Fragmentation split packets to evade simple filters.
- MTU manipulation altered packet sizes to confuse IDS.
- Decoys masked the real IP among fake sources.
- Source port spoofing bypassed firewall rules expecting DNS traffic.

---

5. Risk Rating Summary

Severity	Count	Example Vulnerabilities
Critical	2	vsftpd backdoor, Samba exploit
High	3	Anonymous SMB, weak default accounts
Medium	2	Outdated Apache, SMTP misconfig
Low	3	Banner disclosures

6. Conclusion

The Metasploitable2 VM is in a **High-Risk posture** due to critical exploitable services (FTP, SMB) and weak configurations. Immediate remediation should focus on disabling vulnerable services, patching outdated software, and enforcing strong authentication.

Quick Wins: Disable anonymous SMB, patch vsftpd and Samba, upgrade Apache.
Long-Term Recommendations: Continuous monitoring, regular vulnerability assessments, and red team exercises to validate defenses.

7. Appendices

Tools Used

- **Nmap:** Port scanning, service fingerprinting, NSE scripts.
- **Netcat (nc):** Manual banner grabbing.
- **Telnet:** Service interaction and banner verification.
- **smbclient:** SMB share access.
- **enum4linux:** SMB user/share enumeration.

Command References

All commands are listed under each task for reproducibility.

Glossary

- **Nmap:** Network scanning tool for discovering hosts and services.
- **TCP Connect Scan (-sT):** Completes full handshake, reliable but noisy.
- **SYN Stealth Scan (-sS):** Faster, stealthier, avoids full handshake.
- **UDP Scan (-sU):** Identifies UDP services, slower due to retransmissions.
- **Timing Templates (-T0–T5):** Control scan speed and aggressiveness.
- **Netcat (nc):** Utility for banner grabbing and port interaction.
- **Telnet:** Protocol/tool for plaintext service interaction.
- **SMB (Server Message Block):** Protocol for file sharing; misconfigs expose data.
- **smbclient:** Command-line tool for SMB shares.
- **enum4linux:** Tool for SMB enumeration of users/shares.
- **NSE (Nmap Scripting Engine):** Automates discovery and vulnerability checks.

- **Packet Fragmentation (-f):** Splits packets to evade filters.
- **MTU Manipulation (--mtu):** Alters packet size to confuse IDS.
- **Decoys (-D):** Masks real IP among fake sources.
- **Source Port Spoofing (--source-port):** Makes traffic appear from trusted ports.
- **CVE (Common Vulnerabilities and Exposures):** Standardized identifier for known vulnerabilities.
- **Risk Ratings:**
    - **Critical:** Immediate exploitation risk, remote code execution.
    - **High:** Severe misconfigurations, privilege escalation.
    - **Medium:** Outdated software,

Lets Defend With Pride